

SQL Injection Vulnerability

Name: Matyas Abreham

IDNO: CTC-207-26

Lab 1: SQL Injection Vulnerability in WHERE Clause Allowing Retrieval of Hidden Data

Objective

The application filters products by category using a query like:

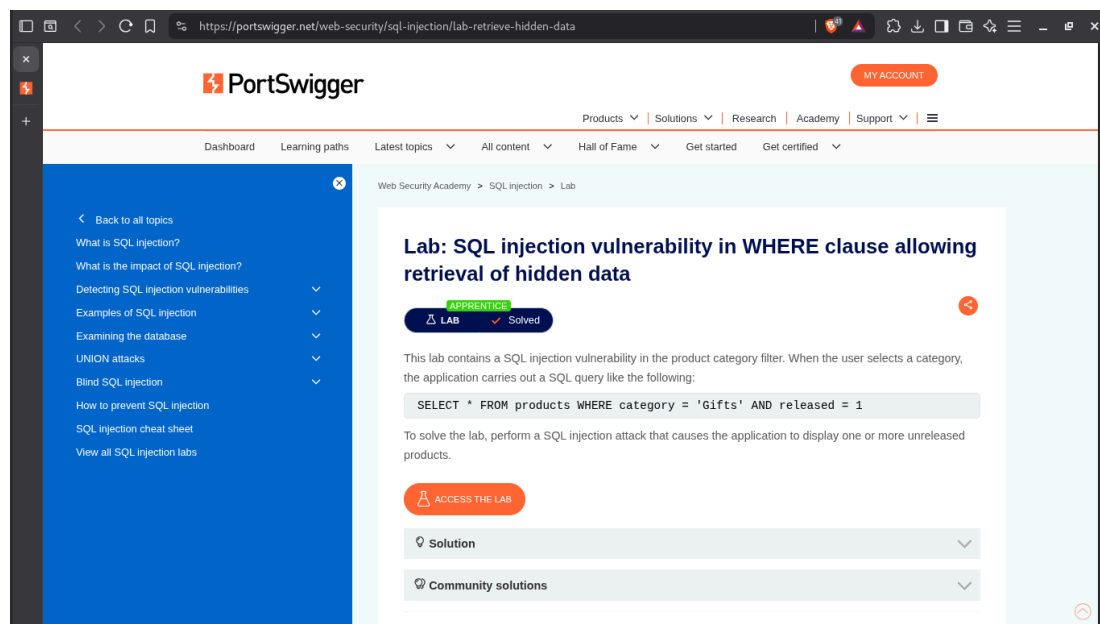
```
SELECT * FROM products WHERE category = 'Gifts' AND released = 1
```

The goal is to perform a SQL injection that displays unreleased products.

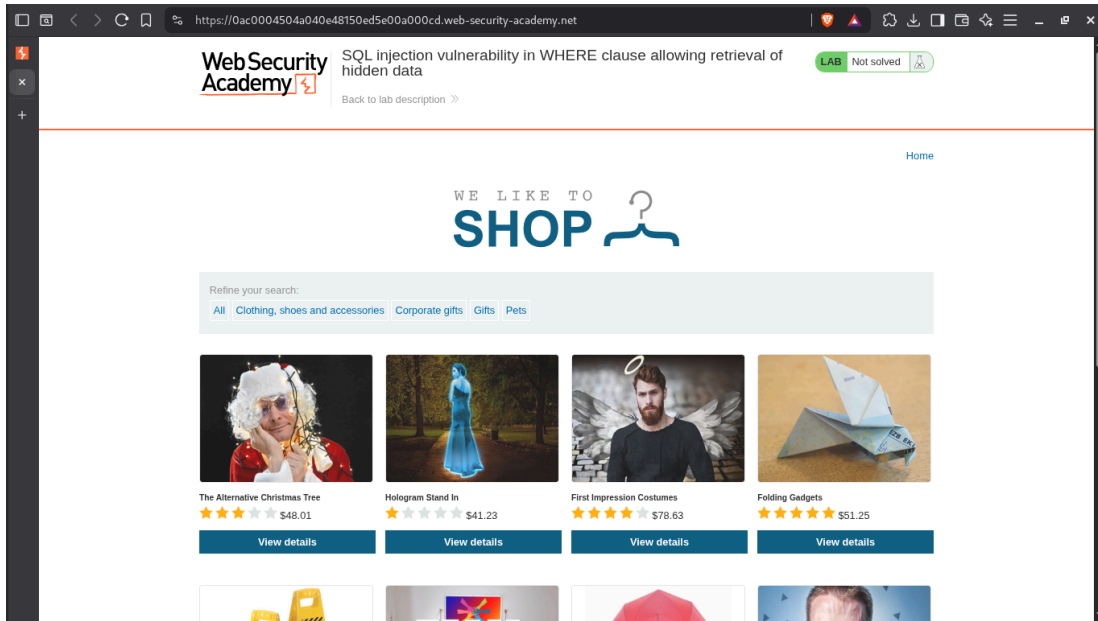
Steps

- Opened the shop and selected the "Gifts" category.
- Intercepted the request in Burp Suite: GET /filter?category=Gifts
- Modified the category parameter to always evaluate true and commented out the rest of the query.

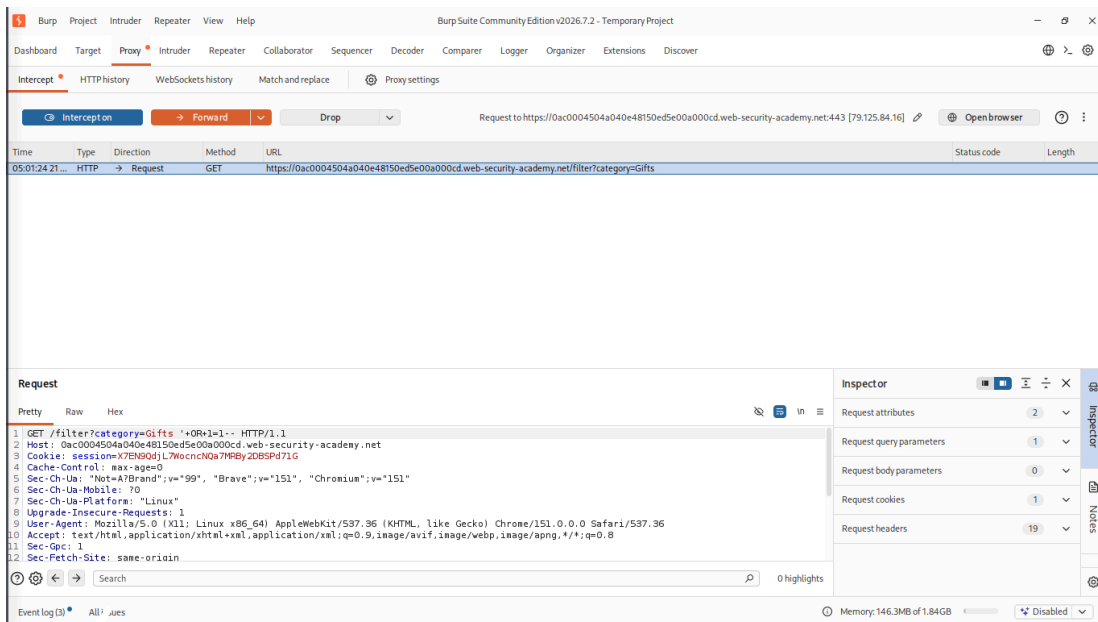
```
category=Gifts' OR 1=1--
```



Lab description page (PortSwigger).



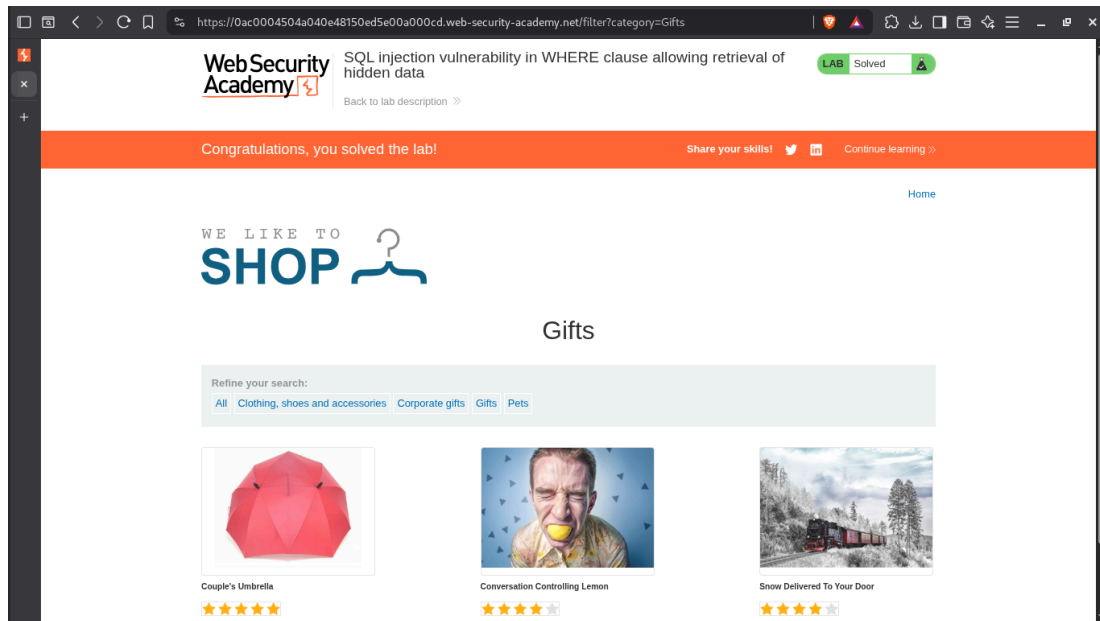
Target shop application before injection.



Burp Suite intercepting the filter request.

Result

The application returned all products, including unreleased ones, confirming the injection worked.



Lab marked as Solved after the injection.

Vulnerability

Unsanitized user input was concatenated directly into a SQL query, allowing the WHERE clause condition to be manipulated.